

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

Empresa: CyberShield Analytics

Rol que responde: CISO

Contexto: Plataforma analítica de Big Data y ciberseguridad con arquitectura Data Lakehouse, uso de Docker, Jupyter, Python, GeoPandas, Scikit-learn, GitHub y Jira; desarrollo actual con dashboard al 30%, API REST al 20% y ML al 80%.

En relación con los controles implementados para la gestión de inventario y control de activos de hardware, responda lo siguiente:

- a. ¿Qué herramienta es utilizada para identificar los dispositivos de la infraestructura tecnológica qué se conecta a la red? Proporcione evidencia que permita validar los siguientes puntos:

La identificación de los componentes tecnológicos del proyecto se realiza mediante la documentación técnica del repositorio y la configuración de infraestructura contenida en GitHub. En particular, se emplean como elementos de control la estructura del proyecto, los archivos de configuración Docker y la documentación de arquitectura, lo que permite identificar los servicios, módulos y componentes que forman parte de la plataforma CyberShield Analytics.

Como evidencia, se cuenta con:

- repositorio central GitHub del proyecto;
- estructura modular del sistema (api, dashboard, data, docker, models, scripts, tests);
- archivo docker-compose.yml;
- carpeta de documentación /docs;
- historial de commits asociados al desarrollo y despliegue de componentes.

Observación de auditoría:

Actualmente, esta identificación corresponde principalmente a la infraestructura lógica y de software del proyecto; para una siguiente etapa se recomienda complementar con una herramienta formal de descubrimiento e inventario de activos de red.

- b. ¿Qué herramienta utiliza para la identificación de direcciones IP de la infraestructura tecnológica? Proporcione evidencia que permita validar los

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.
siguientes puntos.

En el entorno actual, la identificación de direcciones IP se gestiona a nivel de infraestructura de contenedores y entorno local de ejecución (Docker / WSL2 / localhost), por lo que las IP están ligadas a la configuración del ambiente de desarrollo y despliegue.

Estado: Parcialmente implementado

Brecha:

No se observa evidencia de una herramienta centralizada IPAM (IP Address Management).

c. ¿Cómo gestiona las direcciones IP?

Las direcciones IP se gestionan conforme a la configuración del entorno de despliegue Docker y del host donde opera la plataforma. Para ambientes locales, el acceso principal se realiza por localhost, y para despliegues futuros deberá formalizarse un esquema de segmentación y administración IP por ambiente (desarrollo, pruebas, producción).

Recomendación de auditoría: Implementar un control formal con:

- asignación por segmentos,
- registro de IP por activo/servicio,
- reservas estáticas para componentes críticos,
- bitácora de cambios.

d. ¿Se encuentra segmentada la red interna de forma independiente con los centros de datos?

La arquitectura lógica del proyecto contempla separación por capas funcionales (RAW, CLEAN, PROCESSED, GEOSPATIAL, ML, DASHBOARD), pero con la información proporcionada no se acredita una segmentación de red formal entre red interna, centros de datos, entornos o zonas de seguridad.

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

Estado: Pendiente de evidencia

- e. ¿Con qué frecuencia se actualiza el inventario de activos de infraestructura tecnológica?

El inventario de activos tecnológicos del proyecto se actualiza de manera continua conforme se incorporan cambios al repositorio, a la infraestructura de contenedores y a la documentación técnica. La actualización se refleja mediante el historial de commits en GitHub y el seguimiento operativo en Jira, lo que permite mantener trazabilidad sobre nuevas incorporaciones, modificaciones y ajustes al entorno del proyecto.

De manera operativa, la actualización ocurre:

- por evento de cambio técnico;
- por incorporación de nuevos componentes;
- por ajustes a infraestructura, notebooks, modelos o documentación.

Sobre los mecanismos con los que se cuenta para la gestión de inventario y control de activos de software, especifique lo siguiente:

- a. ¿El inventario de software que se tiene es aplicable para toda la empresa o es específico para alguna área?

El inventario de software actualmente corresponde al alcance específico del proyecto CyberShield Analytics, por lo que su aplicación se encuentra focalizada en el entorno técnico y analítico del proyecto. Este inventario incluye herramientas, librerías, dependencias, componentes de infraestructura y módulos de desarrollo asociados a la plataforma.

La trazabilidad del software se mantiene mediante:

- repositorio GitHub;
- archivo requirements.txt;
- configuración de Docker;
- documentación técnica del proyecto.

- b. ¿Se cuenta con procedimientos para la administración de software licenciado? ¿En qué consiste?

Se utilizan componentes con esquemas mixtos:

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- herramientas de código abierto,
- plataformas de colaboración y control,
- entornos de desarrollo y contenedorización.

No se cuenta con evidencia suficiente para afirmar un procedimiento corporativo formal de administración de licencias.

Estado: Parcialmente implementado / pendiente de formalización

Recomendación:

Llevar un inventario de:

- software,
 - versión,
 - tipo de licencia,
 - vigencia,
 - responsable,
 - restricción de uso.
- c. ¿Se utiliza software de código abierto? ¿Qué pruebas se realizan para poner en operación dicho software? ¿Todas las áreas lo pueden utilizar una vez aprobado?
- Sí. Se utiliza software de código abierto, entre ellos:

- Python
- Pandas
- NumPy
- GeoPandas
- Shapely
- Scikit-learn
- Docker
- Jupyter Notebook
- Git/GitHub

Para poner en operación estos componentes se realizan pruebas funcionales y técnicas, entre ellas:

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- ejecución de notebooks de análisis;
- validación de pipelines ETL/ELT;
- transformación y validación de datos en formatos CSV, Parquet y GeoParquet;
- pruebas de procesamiento analítico y entrenamiento de modelos de Machine Learning;
- verificación de consistencia en entornos Docker.

Una vez aprobado técnicamente su uso dentro del proyecto, el software puede ser utilizado por el equipo responsable del desarrollo y operación de CyberShield Analytics, bajo control del repositorio central, documentación técnica y seguimiento mediante Jira.

d. ¿Qué área es la encargada de definir, autorizar y formalizar el software que se utilizará en las estaciones de trabajo?

La definición y autorización funcional recae en la dirección tecnológica del proyecto (CEO/CIO), en conjunto con seguridad (CISO) y el equipo técnico especializado (DevSecOps/DataSecOps/DS), según el tipo de componente.

e. ¿Cómo garantizan que el software utilizado contemple soporte del fabricante?
Para componentes open source, el soporte se apoya en:

- comunidades oficiales,
- documentación técnica,
- control de versiones,
- mantenimiento del ecosistema.

Para ambientes productivos futuros, deberá asegurarse el uso de versiones estables y mantenidas.

f. ¿Cuenta con una herramienta que realice el inventario de software?

Con relación a las actividades implementadas para la gestión continua de vulnerabilidades, responda lo siguiente:

Sí. Actualmente el inventario de software del proyecto se soporta mediante mecanismos técnicos de trazabilidad y control, principalmente a través de:

- el repositorio GitHub del proyecto;
- el archivo requirements.txt, donde se registran las dependencias;
- el archivo docker-compose.yml, que documenta la configuración del entorno;

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- la estructura modular del repositorio;
- la carpeta /docs, donde se documenta la arquitectura y los componentes.

Si bien no se cuenta todavía con una plataforma corporativa especializada de inventario de software, los mecanismos implementados permiten identificar, versionar y dar seguimiento a los componentes utilizados en el proyecto.

Estado: Parcial

a. ¿Se cuenta con herramientas para el escaneo de vulnerabilidades?

Con la información proporcionada no se acredita una herramienta formal y continua de escaneo de vulnerabilidades sobre infraestructura, imágenes, dependencias o código.

Estado: Pendiente

Recomendación del CISO:

Implementar al menos:

- escaneo de dependencias,
- escaneo de contenedores,
- escaneo de configuraciones,
- análisis SAST/DAST.

b. ¿Se realizan pruebas de penetración?

No se proporciona evidencia de ejecución formal de pruebas de penetración sobre ambientes del proyecto.

Estado: Pendiente / en recomendación

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

c. ¿Qué herramientas se utilizan para la ejecución de pruebas de penetración?

No hay evidencia documental de herramientas específicas utilizadas para pruebas de penetración.

d. En relación con los hallazgos identificados como resultado de los análisis de vulnerabilidades y pruebas de penetración, responda lo siguiente:

- ¿Cuál es el proceso de mitigación?
- ¿Se encuentra documentado y formalizado?
- ¿Qué seguimiento se da a estas actividades de mitigación?
- ¿Se generan planes de mitigación?
- ¿Quién es el responsable de su ejecución y vigilar su cumplimiento?

Como resultado de las cinco preguntas previamente planteadas, se presenta la siguiente información:

Los hallazgos de seguridad se gestionan mediante un flujo de tratamiento basado en Jira:

- Identificación del hallazgo.
- Clasificación por criticidad.
- Asignación al responsable técnico.
- Definición de acciones correctivas.
- Validación de remediación.
- Cierre documentado.

Estado: Parcialmente implementado

Existe capacidad de seguimiento mediante Jira, pero no se acredita procedimiento formal documentado de gestión de vulnerabilidades.

Responsables:

- Remediación técnica: DevSecOps / DataSecOps / responsables de desarrollo.
- Supervisión del cumplimiento: CISO.
- Aprobación de riesgos residuales: CIO/CEO y CISO.

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.
Sobre el uso controlado de privilegios administrativos, proporcione las siguientes respuestas:

- a. ¿Se cuenta con herramientas para administrar las cuentas de los usuarios?

No se acredita una solución corporativa centralizada de IAM/PAM/Directorio Activo dentro de la evidencia proporcionada.

Estado: Pendiente / parcial

- b. En relación con la gestión de cuentas con privilegios de administración, responda lo siguiente:

- ¿Tienen un inventario de cuentas privilegiadas?
- ¿Se cuenta con procedimientos documentados y formalizados para su gestión?
- ¿Quién es responsable de autorizar y vigilar el uso de este tipo de cuentas?

Como resultado de las tres preguntas previamente planteadas, se presenta la siguiente información:

Las cuentas privilegiadas se limitan a los administradores del entorno de desarrollo, repositorios y despliegue. Sin embargo, no se cuenta con evidencia suficiente de un inventario formal de cuentas privilegiadas ni de un procedimiento documentado para su gestión.

Responsable propuesto:

CISO en coordinación con DevSecOps y CIO.

- c. ¿Se hace uso de cuentas dedicadas o secundarias para la ejecución de actividades elevadas?

- ¿Cómo se administran?
- ¿Quién es responsable de su custodia?
- ¿En qué sistemas se utilizan y para qué actividades?
- ¿Cómo se protegen dichas cuentas?
- ¿Se realiza algún monitoreo sobre dichas cuentas? ¿Quién lo ejecuta? ¿Qué actividades se realizan en caso de detectarse actividades no autorizadas?

Sobre el subapartado de uso de cuentas dedicadas para actividades elevadas, se plasma lo siguiente:

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

Como medida recomendada y alineada con buenas prácticas, las actividades administrativas deben realizarse mediante cuentas secundarias o dedicadas, separadas de las cuentas de uso diario. Con la información disponible, esto no puede acreditarse como totalmente implementado.

- d. ¿Se cuenta con mecanismos para el alertamiento por intentos fallidos de inicio de sesión en la infraestructura tecnológica?
- ¿Cuál es su alcance?
 - ¿Sobre qué sistemas operan?
 - ¿Considera cuentas privilegiadas?
 - ¿Quién recibe las alertas?
 - ¿Qué actividades se realizan cuando se recibe una alerta? ¿Cómo se registran y documentan?

No se evidencia una solución formal de monitoreo centralizado de autenticaciones fallidas.

Brecha:

Debe integrarse con SIEM/alertamiento.

- e. ¿Se realiza el cambio de contraseñas por defecto en los sistemas?

Sí, como política de seguridad del proyecto, los despliegues y componentes deben operar sin credenciales por defecto. Sin embargo, falta evidencia documental y técnica que demuestre la verificación continua de este control.

En relación con los mecanismos implementados para la configuración segura para hardware y software en dispositivos móviles, computadoras portátiles, estaciones de trabajo y servidores especifique lo siguiente:

- a. ¿Cómo se gestionan las licencias de los sistemas operativos y cómo se aseguran de que toda la infraestructura cuenta con licencias originales y actualizadas?

La infraestructura del proyecto se apoya principalmente en contenedores y entornos de desarrollo. No se cuenta con evidencia documental del proceso corporativo de licenciamiento de sistemas operativos para todos los equipos de la empresa.

- b. Sobre las imágenes definidas para los equipos e infraestructura de la empresa, responda
- ¿Cuáles son los criterios que se usan para crear una imagen oficial para los

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.
dispositivos de la empresa?

- ¿Cuántos tipos de imagen se han definido?
- ¿En qué consisten dichas imágenes? ¿Qué elementos contienen?
- ¿Se encuentran documentadas y formalizadas?
- ¿A qué dispositivos son aplicables?

No se acredita un esquema formal de imágenes maestras corporativas para estaciones, portátiles y servidores.

Estado: Pendiente

- c. ¿Dónde y cómo se resguardan las imágenes autorizadas por la empresa?

De implementarse, deberían resguardarse en un repositorio controlado y con control de integridad. No existe evidencia suficiente para afirmarlo como implementado.

- d. ¿Quién autoriza la imagen predeterminada para los activos y cualquier modificación que se realice a las mismas?

Debería ser autorizada por TI/CIO con validación de seguridad por CISO.

- e. ¿Qué mecanismos que han implementado para la protección de las imágenes y evitar modificaciones no autorizadas?

Pendiente de formalización.

Sobre las actividades que se ejecutan para el mantenimiento, monitoreo y análisis de logs de auditoría, responda lo siguiente:

- a. ¿Cuántas fuentes de sincronización de tiempo (reloj internacional) se tienen para la infraestructura tecnológica?

No se cuenta con evidencia de fuentes NTP formalmente definidas para toda la infraestructura.

- b. ¿Cada cuando se realiza un análisis a las bitácoras de logs?

- ¿Quién realiza el análisis?
- ¿Qué tipo de eventos se rastrean?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- ¿Cuál es el alcance de dicho análisis?
- ¿Qué actividades se realizan en caso de detectar algún evento no autorizado?
- ¿Qué documentación se genera?
- ¿Existe un procedimiento documentado y formalizado?

Actualmente, el proyecto genera trazabilidad técnica a través de los registros provenientes de la ejecución de contenedores, scripts, notebooks y cambios en el repositorio. El análisis de estos registros se realiza principalmente durante actividades de desarrollo, validación técnica y seguimiento de incidencias.

El análisis es efectuado por el equipo técnico responsable del proyecto, principalmente en funciones asociadas a desarrollo, infraestructura y seguridad.

Los eventos que se rastrean actualmente corresponden a:

- ejecución de procesos y notebooks;
- cambios de configuración;
- incorporación o modificación de componentes del proyecto;
- actualizaciones en dependencias;
- evidencias de avance técnico registradas en GitHub y Jira.

La centralización y automatización formal del análisis de logs se encuentra en proceso de maduración, por lo que todavía no se cuenta con una solución SIEM plenamente implementada.

- c. ¿Quién tienen acceso a las bitácoras? ¿Cómo se restringe el acceso a las mismas?
¿Cómo se protege la información que contienen?

El acceso debería restringirse al personal técnico autorizado y al área de seguridad, con controles de permisos y resguardo. **No hay evidencia suficiente para acreditarlo como formalizado.**

- d. ¿Cuentan con una herramienta para el análisis automático de los registros generados por los sistemas de la infraestructura tecnológica?
- ¿Qué herramienta es?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- ¿Cuál es su configuración?
- ¿Quién tiene acceso?
- ¿Qué sistemas, aplicaciones, bases de datos o infraestructura se monitorea?
- ¿Qué registros se revisan?
- ¿Genera alertas?
- ¿Cuáles son los registros o eventos que generan las alertas?
- ¿Quién recibe esas alertas?
- ¿Qué actividades se realizan en relación con esas alertas?
- ¿Qué documentación se genera?
- ¿Se realizan regularmente ajustes al SIEM para configurar nuevas alertas o disminuir falsos positivos?
- ¿Con qué frecuencia?
- ¿Quién realiza, autoriza y supervisa estos ajustes?

No se identifica una herramienta SIEM implementada y operando en el estado actual del proyecto.

Estado: Pendiente

Recomendación:

Implementar una plataforma centralizada de logs y correlación de eventos conforme avance el dashboard y monitoreo.

Con relación a los mecanismos implementados para la protección de correo electrónico y navegador web, proporcione las siguientes respuestas:

- a. ¿Se han configurado los equipos para restringir la descarga de navegadores de internet diferentes al autorizado por la empresa?

No se acredita una política técnica de restricción corporativa de navegadores.

- b. ¿Se han configurado los navegadores de las estaciones de trabajo y equipos de cómputo personales para limitar la activación y desactivación de Plugins? ¿Qué mecanismos se han implementado en relación con la gestión de cookies? ¿Qué otras medidas o configuraciones se han realizado para mantener una configuración segura de los navegadores?

No hay evidencia documental.

- c. ¿Qué herramientas son utilizadas para detectar correos o páginas maliciosas?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- ¿Cuál es su configuración?
- ¿Qué tipo de páginas o correos se restringen?
- ¿Quién las administra?
- ¿Funciona a través de listas blancas o negras? ¿Con qué frecuencia se actualiza?
- ¿Genera algún tipo de alerta?
- ¿A quién se les notifica las alertas?
- ¿Qué actividades se realizan en relación con las alertas?
- ¿Cómo se documentan dichas actividades?

No se proporcionó información al respecto.

- d. ¿Se realiza algún tipo de análisis con los correos o URL's maliciosas que detecta la herramienta?

Pendiente.

- e. ¿Se ha limitado el uso de lenguajes de scripting en navegadores de internet y clientes de correo electrónico? ¿Cuál es el alcance y a quién aplica dicha limitante?

Pendiente.

- f. ¿Se tiene registro de todas las peticiones de URL de cada uno de los sistemas de la empresa?
- ¿Cómo se registran dichas peticiones?
 - En relación con el registro de dichas peticiones, ¿se utiliza para identificar actividades potencialmente maliciosas y ayudar a los responsables de gestionar incidentes a identificar sistemas potencialmente comprometidos?
 - ¿Qué actividades se realizan en caso de identificar actividades maliciosas?
 - ¿Cómo se documentan dichas actividades?

No se acredita.

- g. ¿Se cuenta con servicios de filtrado DNS para el bloqueo de dominios maliciosos? Proporcione evidencia que justifique su respuesta.
- ¿En qué consisten dichos servicios?
 - ¿Aplica para toda la empresa?
 - ¿En caso de identificar dominios maliciosos se realiza alguna notificación?
 - ¿Quién la recibe?
 - ¿Qué medidas se toman?
 - ¿Cómo se documentan?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

No se acredita evidencia.

- h. ¿Se utiliza el Sandbox para análisis y bloqueo de información adjunta en los correos electrónicos?

No se acredita.

- i. ¿Se cuenta con una política de Autenticación, Reporte y Conformidad de mensajes basada en dominio (Domain-based Message Authentication, Reporting and Conformance - DMARC) implementada, así como estándares Sender Policy Framework (SPF) y DomainKeys Identified Mail (DKIM)?

No se proporciona evidencia.

Conclusión de la sección:

Esta sección presenta brecha importante de evidencia y diseño formal de seguridad corporativa de correo y navegación.

Sobre los controles implementados para la defensa contra malware, especifique lo siguiente:

- a. ¿Como se protege las aplicaciones ante un ataque de croo scripting en las aplicaciones en producción?

Dado que la API y dashboard aún están en maduración, la protección de aplicaciones web deberá contemplar:

- validación de entradas,
- sanitización,
- escaping de salida,
- cabeceras seguras,
- WAF en producción.

Estado actual: Parcial / en diseño

- b. ¿Se cuenta con mecanismos de análisis de medios extraíbles que se ejecuten de forma automática cuando éstos se conectan a los equipos de cómputo y/o servidores?
- ¿En qué consisten?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- ¿Cuál es su alcance?
- ¿Aplica para todos los equipos o servidores?
- ¿Existen excepciones?
- ¿Cómo se gestionan dichas excepciones?

No se acredita evidencia.

- c. ¿Cómo se lleva a cabo la actualización de la herramienta antivirus? ¿Con qué frecuencia? ¿Cómo se aseguran de que todos los equipos conectados a la red de la empresa se actualizan?

No se proporciona información sobre antivirus corporativo ni consola central.

- d. ¿Se cuenta con mecanismos anti-explotación como la prevención de ejecución de datos (Data Execution Prevention - DEP)
o Address Space Layout Randomization (ASLR)? ¿Cuáles son? ¿En qué consisten?

Estos mecanismos dependerán del sistema operativo y configuración de endpoints/servidores; no se acredita su gestión centralizada.

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- e. ¿Se ha restringido la ejecución automática de contenido? ¿Cuáles son los mecanismos implementados? ¿Se han aplicado a la totalidad de la infraestructura que se encuentra conectada a la red de la Empresa?

No se acredita.

- f. ¿Se han habilitado las bitácoras para registrar el uso de línea de comandos? Proporcione evidencia que soporte sus respuestas.
- ¿Se han habilitado en todos los equipos?
 - ¿Se considera para los servidores?
 - ¿Quién tiene acceso a dichas bitácoras?
 - ¿Cómo se protegen de modificaciones no autorizadas?
 - ¿Se realizan revisiones a dichas bitácoras? ¿Quién las ejecuta?
 - ¿Qué actividades se realizan en caso de identificar eventos no autorizados?
 - ¿Cómo se documentan?

No se acredita evidencia formal de habilitación y monitoreo.

Sobre la limitación y control de puertos de red, protocolos y servicios, responda lo siguiente:

- a. ¿Se cuenta con mecanismos que permitan asociar puertos, servicios y protocolos activos al inventario de activos?

No se identifica mecanismo formal.

- b. ¿Como se aseguran de que en cada sistema se ejecuten solo los puertos de red, los protocolos y los servicios que se requieran?

Actualmente esto puede gestionarse parcialmente mediante configuración de contenedores y servicios expuestos en Docker Compose; sin embargo, no se acredita una política de hardening de red formal.

- c. ¿Se realizan escaneos de puertos y con qué periodicidad?

No hay evidencia de periodicidad definida.

- d. ¿Se cuenta con mecanismos de filtrado de puertos para limitar el tráfico de la red?

No se acredita evidencia técnica.

- e. ¿Se cuenta con una solución WAF (Web Application Firewall) para el monitoreo de tráfico que va hacia los servidores en producción? ¿Qué herramienta es? ¿Cuál

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.
es su alcance?

No se observa una solución WAF implementada. Dado que la API REST y dashboard aún están en desarrollo, este control debe considerarse obligatorio antes del paso a producción.

En relación con la capacidad de recuperación de datos, especifique lo siguiente:

- a. ¿Quién es responsable de prestar el servicio de respaldo a la empresa? ¿Cuál es el alcance de dichos servicios? Proporcione el contrato y el anexo técnico correspondiente a dicho servicio.
- ¿Cómo se aseguran del cumplimiento de dichos servicios?
- ¿Cómo se aseguran de que los respaldos generados son suficientes y adecuados?

No se proporciona evidencia de proveedor, contrato o anexo técnico de respaldos.

b. Describa el proceso de respaldo de información.

- ¿Se encuentra documentado y formalizado?
- ¿Cuál es la información que se respalda?
- ¿Cómo se determinó el alcance de los respaldos?
- ¿Con qué frecuencia se ejecutan los respaldos de información?

La información crítica del proyecto incluye:

- datasets raw/clean/processed,
- geoparquet,
- notebooks,
- scripts,
- modelos,
- configuraciones,
- documentación,
- repositorio Git.

No obstante, no se acredita un procedimiento formal, documentado y calendarizado de respaldo.

- c. ¿Cómo se protegen los respaldos de seguridad? ¿Se han implementado mecanismos de cifrado para su protección? ¿Cuáles son dichos mecanismos?

No se aporta evidencia.

- d. ¿En dónde se resguardan los respaldos de la empresa? ¿Cuáles son los mecanismos que se han implementado para restringir el acceso físico a los mismos?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

No se acredita.

Recomendación del CISO:

Formalizar estrategia 3-2-1, cifrado, periodicidad, pruebas de restauración y control de acceso.

Sobre los controles para una configuración segura de los equipos de red, tales como cortafuegos, enrutadores y conmutadores, responda:

- a. ¿Se cuenta con alguna herramienta que verifique las configuraciones de los equipos de red y detecte los cambios de éstos?

No acreditada.

- b. ¿Se cuenta con mecanismos de autenticación multi- factor y sesiones cifradas para los equipos de red? ¿Cuáles son?

No acreditado.

- c. ¿Se cuenta con equipos de cómputo dedicados exclusivamente para la ejecución de actividades de administración de la red?

No acreditado.

Con relación a los mecanismos con los que se cuenta para la seguridad perimetral, especifique lo siguiente:

- a. ¿Se realizan escaneos desde el exterior del de cada red de confianza para detectar cualquier conexión no autorizada accesible a través del perímetro?

No documentados.

- b. ¿Qué mecanismos se han implementado para denegar la comunicación sobre los puertos TCP o UDP no autorizados o el tráfico de aplicaciones para garantizar que solo los protocolos autorizados puedan cruzar el límite de la red hacia o desde la red, en cada uno de los límites de la red de la empresa?

No documentadas.

- c. ¿Se cuenta con un proxy para la seguridad perimetral? ¿para qué servicios es utilizado?

No acreditado.

- d. ¿Qué servicios se protegen en la DMZ?

No identificada.

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- e. ¿Cuáles son los mecanismos implementados para la autenticación de las conexiones de red?

No documentada.

- f. ¿Cómo se deniegan las comunicaciones mediante IP en los routers?

No acreditado.

- g. ¿Cómo se lleva a cabo el monitoreo por medio de IDS e IPS en la red?

¿Cuáles son las reglas configuradas? ¿Se detectaron eventos durante el año en curso? ¿Cómo se atendieron los eventos detectados?

No acreditado.

La seguridad perimetral formal **no puede considerarse implementada con la evidencia disponible.**

Sobre las actividades con las que se cuenta para la protección de datos, proporcione su respuesta:

- a. ¿Se cuenta con un inventario de información crítica o sensible de la empresa?

Sí, a nivel de proyecto se tiene identificada la información crítica y sensible asociada a la operación de CyberShield Analytics. Entre los principales activos de información se encuentran:

- dataset fuente de eventos de ciberseguridad;
- datos transformados en capas RAW, CLEAN y PROCESSED;
- archivos GeoParquet y estructuras geoespaciales;
- modelos de Machine Learning;
- notebooks, scripts y configuraciones de procesamiento;
- documentación técnica del proyecto;
- variables de entorno y archivos de configuración.

Actualmente, esta identificación se encuentra reflejada en la estructura del repositorio, en la organización por capas del Data Lakehouse y en la documentación técnica del proyecto.

Como mejora futura, se recomienda formalizar esta identificación en una matriz de clasificación de información.

- b. ¿Cuenta con una herramienta DLP para el monitoreo de información en la red?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

No se acredita.

- c. ¿Cuenta con un inventario de los terceros que tienen acceso a servicios en la nube y/o correo electrónico institucional?

No se acredita.

- d. ¿Cuenta con una herramienta para el bloqueo de tráfico en caso de detectar transferencia no autorizada de información sensible?

No se acredita.

- e. ¿Qué método de cifrado se utiliza para los discos duros de todos los dispositivos?

No se aporta evidencia.

- f. En caso de permitir el uso de dispositivos de almacenamiento USB ¿Se cuenta de un inventario de dispositivos de almacenamiento USB autorizados para uso exclusivo en la empresa?

No se aporta evidencia.

- g. ¿Se cifra la información de los dispositivos USB que son autorizados por la empresa? ¿Qué tipo de cifrado se utiliza?

No se aporta evidencia.

- h. ¿Cómo se aseguran de que la información crítica no puede ser extraída de los dispositivos (estación de trabajo, móviles, Tablet)?

No se acredita un control formal DLP o MDM.

Con relación a la implementación de mecanismos de control de acceso basado en la necesidad de conocer, responda lo siguiente:

- a. ¿Se ha segmentado la red considerando el nivel de clasificación de la información almacenada en los servidores?

La arquitectura funcional sí está segmentada por capas de datos, pero no se acredita segmentación de red formal basada en clasificación de información.

- b. ¿Se cifra toda la información sensible en la red institucional? ¿Qué mecanismo de cifrado se utiliza?

No se aporta evidencia documental del mecanismo corporativo de cifrado en tránsito.

- c. ¿Están configuradas las estaciones de trabajo para restringir la comunicación entre ellas?

No se acredita.

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- d. ¿Se tiene habilitado el filtrado de firewall entre las VLAN para permitir solo la comunicación entre sistemas necesarios y específicos?

No se acredita.

- e. ¿Se cuenta con herramientas para el cifrado de información sensible en reposo?
Sobre las actividades para el control de acceso inalámbrico, especifique lo siguiente:

No se evidencia una herramienta formalmente incorporada.

¿Qué mecanismos de cifrado se utilizan para la información en tránsito en la red inalámbrica?

- ¿Cuentan con algún sistema inalámbrico de detección de intrusos (WIDS) para detectar y alertar sobre puntos de acceso inalámbrico no autorizados conectados a la red?
- ¿Cuentan con un inventario de los puntos de acceso a nivel nacional actualizado?
- ¿Qué tipo de estándar se utiliza para el cifrado de información en las redes inalámbricas?
- ¿Qué tipo de protocolos de autenticación son utilizados en sus redes inalámbricas?
- ¿Se tiene deshabilitado los accesos periféricos (bluetooth y NFC) en las redes inalámbricas?
- ¿Cuentan con una red inalámbrica separada y de diferente segmento para usuarios que no pertenecen a la empresa (¿invitados, proveedores entre otros?)?

Con la información del proyecto no es posible acreditar controles de red inalámbrica corporativa, tales como:

- WIDS,
- inventario de AP,
- estándares de cifrado Wi-Fi,
- autenticación,
- deshabilitación Bluetooth/NFC,
- red separada para invitados.

Conclusión: aplica como fuera de alcance de la evidencia actual o pendiente de documentación corporativa.

En relación con el monitoreo y control de cuentas, responda lo siguiente:

- a. ¿Cuentan con un inventario de los sistemas de autenticación?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

No se acredita formalmente.

- b. ¿Se cuenta con mecanismos de autenticación multifactor para el acceso a todos los sistemas de la empresa?

No se acredita evidencia integral.

- c. ¿Qué tipo de cifrado de credenciales de autenticación es utilizado y que alcance tiene?

Debería sustentarse por tecnología específica; no se provee evidencia.

- d. ¿Cuenta con mecanismos que alerten los inicios de sesión que presentan un comportamiento anormal en los sistemas?

No se acredita.

- e. ¿Se ha configurado el bloqueo de las estaciones de trabajo tras pasar por un periodo de inactividad? En caso afirmativo ¿Cómo se aseguran de que la política se aplique a todos los equipos?

No se aporta evidencia corporativa.

- f. ¿Qué políticas se han definido con relación a la vigencia de las cuentas de usuarios en los sistemas?

- ¿Cuál es el tiempo máximo de vida de las cuentas?
- ¿Cómo se realiza la configuración de la caducidad de las cuentas?
- ¿Existen excepciones?
- ¿Cómo se gestionan dichas excepciones?
- ¿Se cuenta con algún mecanismo para gestionar de manera centralizada la caducidad de las cuentas de usuario? (p.e. Directorio Activo). En caso contrario ¿Cómo se aseguran de que las políticas son aplicadas a todas las cuentas de usuarios?

No se acredita un control centralizado documentado.

- g. ¿Cuentan con un inventario de las cuentas que se eliminan o están desactivadas en la empresa?

- ¿Quién es el responsable de gestionar y actualizar dicho inventario?
- ¿Cómo se actualiza y con qué frecuencia?

No se acredita.

Sobre las actividades definidas para implementar un programa de concienciación y entrenamiento de seguridad, especifique lo siguiente:

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- a. ¿Cuentan con un programa de concientización en materia de seguridad de la información?

Sí, dentro del proyecto se promueve la concientización en seguridad de la información a nivel del equipo técnico, especialmente en temas relacionados con manejo de datos, control de acceso, uso de repositorios, resguardo de configuraciones, trazabilidad de cambios y buenas prácticas de desarrollo.

Esta concientización se fortalece mediante:

- documentación técnica del proyecto;
- control de versiones en GitHub;
- seguimiento de actividades y responsables en Jira;
- participación coordinada del equipo técnico y de seguridad.

No obstante, el programa aún se encuentra en una etapa de consolidación formal, por lo que se considera como una práctica implementada a nivel de proyecto, con oportunidad de evolucionar hacia un esquema más estructurado y documentado.

- b. ¿Como se verifica el cumplimiento del programa de concientización en materia de seguridad de la información?

Debería medirse mediante asistencia, evaluaciones y evidencia de capacitación. **No se acredita evidencia completa.**

- c. ¿Qué criterios son utilizados para la definición de las necesidades del personal en materia de capacitación de seguridad de la información? ¿Cómo se identifican dichas necesidades?

Se determinan según el rol:

- Data Scientist,
- DevSecOps,
- DataSecOps,
- desarrollo de API/dashboard,
- administración de infraestructura,
- seguridad.

- d. ¿El programa de concientización en materia de seguridad de la información es para todo el personal?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

Sí, debe aplicar a todo el personal, con profundidad diferenciada según rol.

- e. ¿Se considera algún marco de ciberseguridad o cuáles son los fundamentos para definir el programa de concientización de seguridad de la información?

El programa debe basarse en marcos de seguridad, gestión de riesgos y buenas prácticas de desarrollo seguro.

- f. ¿El personal se capacita con base en la clasificación de la información a la que tienen acceso con la finalidad de asegurar la protección de esta?

Debe implementarse; no hay evidencia suficiente de formalización.

En relación con la seguridad del software de aplicación, proporcione las siguientes respuestas:

- a. ¿Cuentan con una herramienta autorizada para el escaneo dinámico y estático de código para las aplicaciones en la empresa?

No se acredita.

- b. ¿Cómo validan los estándares de seguridad en los aplicativos desarrollados por terceros antes de su adquisición?

No se documenta procedimiento.

- c. ¿El personal del área de desarrollo cuentan con capacitación, así como certificaciones que acrediten su habilidad para escribir código seguro? ¿Cuáles son dichas capacitaciones y certificaciones?

No se aporta evidencia formal.

- d. ¿Cuentan con ambientes separados de desarrollo, prueba y producción?

El proyecto cuenta actualmente con una separación lógica de ambientes a través de su arquitectura modular, la organización del repositorio y el uso de contenedores Docker, lo que permite controlar de forma diferenciada las actividades de desarrollo y validación técnica.

La estructura del proyecto y la configuración del entorno permiten:

- aislar componentes por función;
- gestionar dependencias de manera controlada;
- reproducir el entorno de trabajo mediante Docker y Docker Compose;
- preparar la evolución hacia ambientes diferenciados de prueba y producción.

A la fecha, la separación formal completamente productiva se encuentra en proceso de consolidación conforme avanza el desarrollo del dashboard y del API REST.

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- e. ¿La Empresa cuenta con aplicaciones web? En caso afirmativo ¿Se tiene un firewall de aplicaciones web (WAF) en la empresa?

Sí se prevé componente web (dashboard y API), pero no se acredita WAF implementado.

- f. ¿Se llevan a cabo actividades de hardening para los sistemas e infraestructura de la Empresa?

No se acredita un estándar formal de hardening.

- g. ¿Se cuenta con plantillas de configuración de hardening estándar para bases de datos?

No se acredita.

Sobre las actividades implementadas para la respuesta y manejo de incidentes, responda lo siguiente:

- a. Ante un ataque cibernético ¿Se han definido tiempos de respuesta para asegurar la continuidad del negocio? ¿Cuáles son dichos tiempos? ¿Cuáles han sido los criterios considerados para su definición? ¿Se cuenta con un Análisis de Impacto al Negocio?

No se acredita un plan formal de respuesta a incidentes con:

- SLAs,
- severidades,
- RTO/RPO,
- análisis de impacto al negocio (BIA).

Recomendación crítica del CISO:

Formalizar plan IR con clasificación de incidentes, escalamiento y tiempos objetivo.

- b. ¿Se cuenta con fuentes externas (nacionales e internacionales) para recibir información en materia de seguridad cibernética y prevenir cualquier acontecimiento que pueda afectar a la empresa?

No se proporciona evidencia.

- c. ¿La empresa mantiene comunicación con organizaciones, autoridades, CERT's o algún otro grupo, con la finalidad de notificar vulnerabilidades o incidentes de gran importancia?

No se acredita formalmente.

- d. ¿Cuáles son los criterios para definir los niveles de criticidad ante un ataque o vulnerabilidad en la infraestructura tecnológica de empresa?

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

La criticidad debe determinarse por:

- impacto en confidencialidad, integridad y disponibilidad,
- afectación a datos sensibles,
- impacto operativo,
- exposición externa,
- probabilidad de explotación,
- persistencia del incidente.

- e. ¿Se realizan pruebas de escenarios de incidentes de seguridad cibernética con los usuarios de la empresa simulando algún evento para verificar tiempos de respuesta?

No se aporta evidencia.

Con relación a la ejecución de pruebas de penetración y ejercicios de equipo rojo, especifique lo siguiente:

- a. ¿Se cuenta con un programa de pruebas de penetración?

No se acredita formalmente.

- b. ¿Se llevan a cabo pruebas de equipo rojo para la detección de vulnerabilidades en los sistemas e infraestructura tecnológica?

No se acredita.

- c. ¿Se realizan pruebas de presencia de información y artefactos no protegidos?

No se acredita.

- d. ¿Cuentan con un banco de pruebas para elementos que normalmente no se realizan en sistemas de producción?

El entorno de notebooks, contenedores y desarrollo puede funcionar como base de pruebas técnicas, pero no se demuestra un laboratorio formal de seguridad o sandbox de validación ofensiva.

Conclusión ejecutiva de auditoría

Fortalezas observadas

CyberShield Analytics presenta una base tecnológica sólida en analítica y procesamiento de datos, con implementación clara de:

- arquitectura Data Lakehouse,
- pipelines ETL/ELT,
- capas RAW/CLEAN/PROCESSED/GEOSPATIAL,

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

- uso de Docker/Docker Compose,
- control de versiones mediante Git/GitHub,
- seguimiento de actividades a través de Jira,
- integración de modelos de Machine Learning y análisis geoespacial.

Lo anterior demuestra un nivel adecuado de madurez técnica en ingeniería de datos y analítica, así como una base sólida para la evolución hacia controles formales de ciberseguridad.

Principales brechas de auditoría

Desde la perspectiva de seguridad de la información, se identifican las siguientes áreas de oportunidad prioritarias:

1. **Falta de formalización documental** (políticas, procedimientos, matrices de acceso, inventarios, evidencias, aprobaciones).
2. **Ausencia de herramientas explícitas de seguridad operativa** (SIEM, DLP, IAM/PAM, escaneo de vulnerabilidades, WAF, IDS/IPS, MDM e IPAM).
3. **Evidencia limitada de controles corporativos** en ámbitos como protección de correo y navegación, gestión de respaldos, hardening, cifrado, segmentación de red y manejo de incidentes.
4. **Madurez parcial de la capa productiva** derivado de que componentes clave como el dashboard y la API REST se encuentran en desarrollo, lo que implica que varios controles aún están en fase de diseño o pendientes de implementación.

CyberShield Analytics cuenta con una arquitectura tecnológica robusta y un nivel avanzado de madurez en el procesamiento analítico de datos, sustentado en el uso de tecnologías modernas como Data Lakehouse, Docker, control de versiones y herramientas de análisis de datos.

Asimismo, se identifica la existencia de controles técnicos que permiten la

Cuestionario relacionado con administración de riesgos en tecnologías de información y comunicaciones para Big Data & Data.

trazabilidad, documentación y gestión estructurada del ciclo de desarrollo, evidenciados a través del repositorio Git, la documentación técnica y el seguimiento de actividades mediante herramientas de gestión como Jira.

No obstante, la organización se encuentra en una etapa de consolidación respecto a la formalización de controles de ciberseguridad a nivel corporativo. Si bien existen prácticas y mecanismos técnicos implementados, varios controles clave (como gestión de vulnerabilidades, monitoreo centralizado, control de accesos, protección de datos y respuesta a incidentes) aún requieren fortalecerse mediante políticas, procedimientos y herramientas especializadas que aseguren su operación continua y verificable.

En este sentido, se concluye que la organización dispone de una base técnica sólida y evidencia operativa relevante, pero presenta un nivel de madurez intermedio en términos de ciberseguridad, con oportunidades claras de mejora para alinearse con buenas prácticas y estándares de gestión de seguridad de la información.

Se recomienda definir e implementar un plan integral de fortalecimiento de ciberseguridad que priorice la formalización de controles, la adopción de herramientas especializadas y la maduración de procesos operativos, con el objetivo de evolucionar desde un enfoque técnico hacia un modelo de gestión de seguridad alineado a estándares y mejores prácticas.